PENETRATION TEST REPORT

vsftpd 2.3.4 Backdoor Exploitation

Target: Metasploitable 2 | 192.168.56.102

Prepared By: Sana Fathima

Date: February 23, 2026

Engagement Type: Simulated Black-Box Penetration Test

Environment: Isolated VirtualBox Lab – Host-Only Network

Tools Used: Kali Linux, Nmap 7.94, Metasploit Framework v6.4.34

Classification: CONFIDENTIAL – Portfolio / Educational Use Only

⚠ *All testing was performed in an isolated lab environment with no real systems at risk.*

1. Executive Summary

This report documents a simulated black-box penetration test conducted against a Metasploitable 2 virtual machine running on an isolated VirtualBox host-only network. The assessment was performed from a Kali Linux attack machine and progressed through full reconnaissance, exploitation, and post-exploitation phases.

A critical vulnerability in the vsftpd 2.3.4 FTP service (CVE-2011-2523) was successfully exploited using the Metasploit Framework, resulting in unauthenticated remote root access to the target system. Post-exploitation activities confirmed complete system compromise, including enumeration of all user accounts, extraction of password hashes, and network reconnaissance of adjacent hosts.

Item	Detail
Target IP	192.168.56.102
Target OS	Linux metasploitable 2.6.24-16-server (Ubuntu)
Exploit Used	exploit/unix/ftp/vsftpd_234_backdoor
CVE Reference	CVE-2011-2523
Access Achieved	Root (uid=0, gid=0)
Overall Risk Rating	CRITICAL
System Compromised?	YES – Full root access confirmed

2. Scope and Objectives

2.1 Objectives

- Perform reconnaissance to identify open services and software versions on the target
- Identify and select an exploitable vulnerability based on scan results
- Exploit the identified vulnerability to gain unauthorised remote access
- Conduct post-exploitation activities to demonstrate the depth of compromise
- Document all findings with evidence and provide remediation recommendations

2.2 Engagement Scope

Parameter	Value
Target	Metasploitable 2 VM
Target IP	192.168.56.102
Attacker IP	192.168.56.101 (Kali Linux)
Network	VirtualBox Host-Only (192.168.56.0/24)

Parameter	Value
Scope	Single target, all ports and services
Out of Scope	Any system outside the lab network
Test Date	February 23, 2026
Duration	Approx. 45 minutes

3. Methodology

This assessment followed the standard penetration testing lifecycle, progressing through four phases: Reconnaissance, Vulnerability Analysis, Exploitation, and Post-Exploitation.

Phase	Activity	Tool
1 – Reconnaissance	Host discovery, port scanning, service enumeration	Nmap
2 – Analysis	Identify vulnerable services, select exploit module	Metasploit (search)
3 – Exploitation	Execute vsftpd backdoor exploit, obtain shell	Metasploit (exploit)
4 – Post-Exploitation	Enumerate users, extract hashes, network recon	Linux shell commands

4. Reconnaissance

4.1 Service Version Scan

An Nmap service version scan was conducted against the target to enumerate all open TCP ports and identify running software versions. This phase is critical for identifying which services may be vulnerable.

```
nmap -sV 192.168.56.102
```

The scan completed in 12.30 seconds and identified 23 open TCP ports. Key findings relevant to this engagement:

Port	Service	Version	Risk
21/tcp	FTP	vsftpd 2.3.4	□ CRITICAL – Known backdoor (CVE-2011-2523)
22/tcp	SSH	OpenSSH 4.7p1	□ Medium – Outdated
23/tcp	Telnet	Linux telnetd	□ High – Plaintext credentials

Port	Service	Version	Risk
139/445/tcp	SMB	Samba 3.x-4.x	High – Remote code execution risk
1524/tcp	Shell	Metasploitable root shell	CRITICAL – Open backdoor
3306/tcp	MySQL	MySQL 5.0.51a	High – Outdated, externally exposed
6667/tcp	IRC	UnrealIRCd	CRITICAL – Known backdoor

Based on these findings, the vsftpd 2.3.4 service on port 21 was selected as the primary attack vector due to its well-documented backdoor vulnerability (CVE-2011-2523) and "excellent" reliability rating in the Metasploit module database.

5. Exploitation

5.1 Launching Metasploit Framework

The Metasploit Framework was launched from the Kali Linux attack machine using the msfconsole command. Metasploit v6.4.34-dev was confirmed running with 2,461 available exploit modules.

```
msfconsole
```

Figure 1 – Metasploit Framework successfully launched (msfconsole)

5.2 Locating the vsftpd Exploit Module

The built-in search function was used to locate the vsftpd exploit module. Two results were returned: a Denial of Service auxiliary module (not used) and the primary backdoor exploitation module rated "excellent" – confirming high reliability.

```
search vsftpd
```

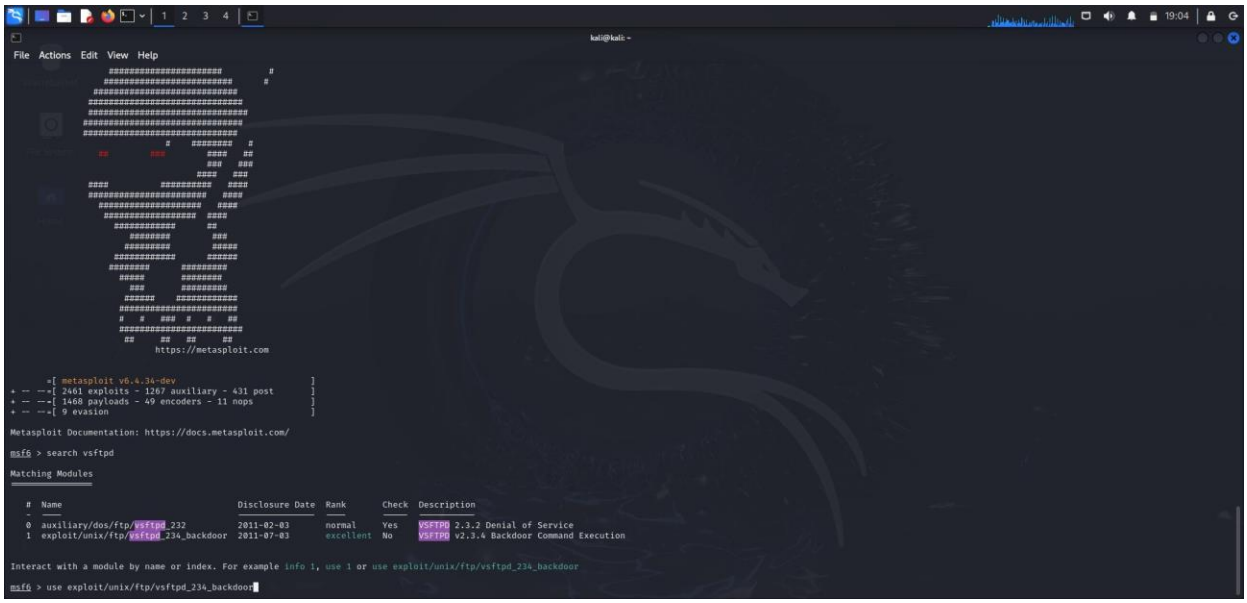

Figure 2 – Search results showing exploit/unix/ftp/vsftpd_234_backdoor (rated: excellent)

5.3 Configuring and Executing the Exploit

The vsftpd backdoor exploit module was loaded and configured with the target IP address. The exploit works by sending a specially crafted username containing a smiley face character (:)), which triggers the hidden backdoor to open a shell listener on TCP port 6200 of the target machine.

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.102
exploit
```

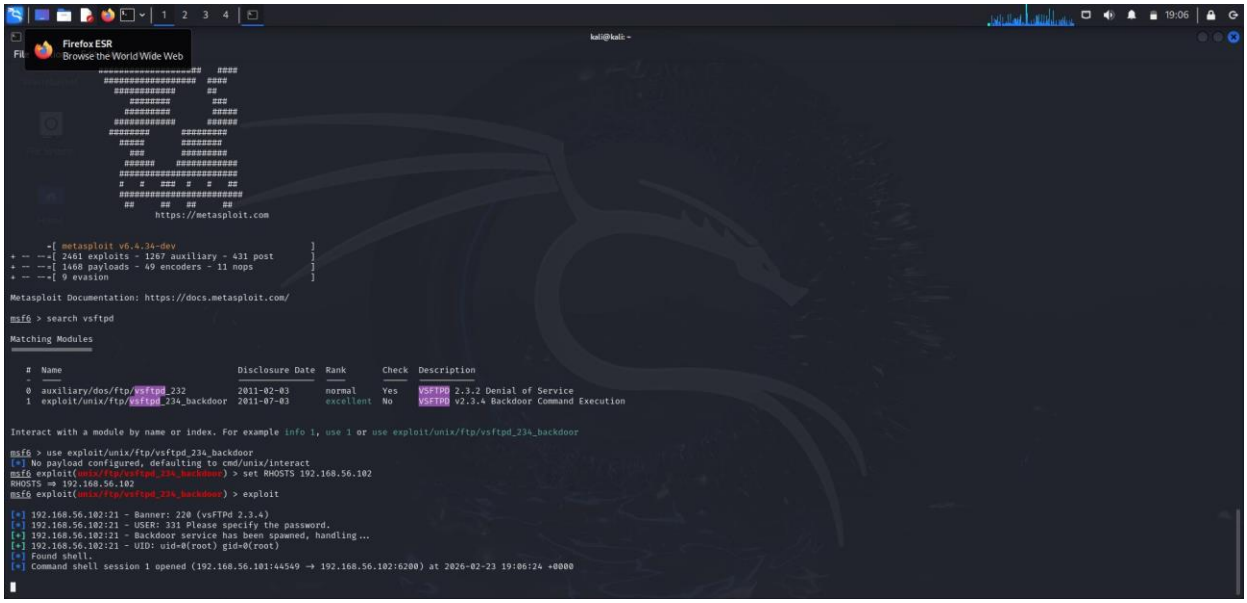

Figure 3 – Exploit execution: backdoor service spawned, shell session opened on port 6200

The exploit output confirmed the following sequence:

- Connected to target FTP banner: 220 (vsFTPd 2.3.4)
- Backdoor trigger sent – service responded and spawned the backdoor handler
- Target confirmed UID: uid=0(root) gid=0(root) – root-level access obtained
- Command shell session 1 opened: 192.168.56.101:44549 → 192.168.56.102:6200

5.4 Root Access Confirmed

CRITICAL FINDING – Unauthenticated Remote Root Access Achieved

Immediately upon shell access, the whoami command was executed to confirm the privilege level of the obtained shell. The output confirmed root, meaning complete administrative control over the target system was achieved without any valid credentials.

```
whoami
```

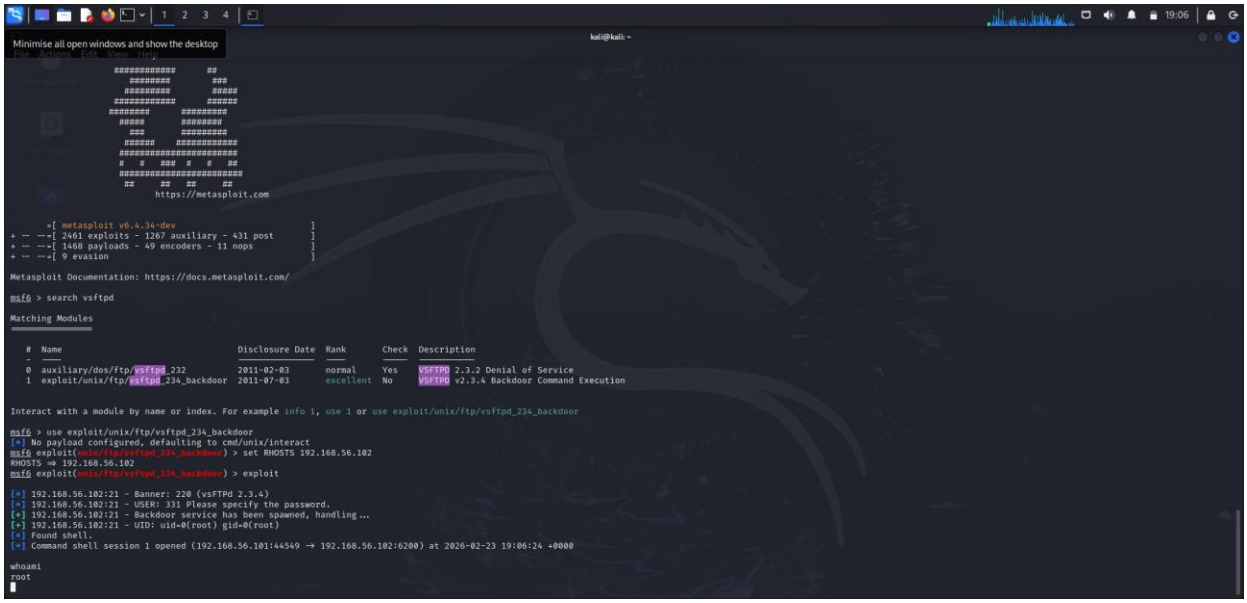

Figure 4 – whoami returns "root" confirming full system compromise (uid=0)

6. Post-Exploitation

Following successful exploitation, a series of post-exploitation commands were executed to demonstrate the depth of system access and gather intelligence, mirroring what a real attacker would do after gaining entry.

6.1 Operating System Fingerprinting

The uname -a command was executed to identify the exact operating system, kernel version, and architecture of the compromised target. This information would be used by an attacker to identify further privilege escalation techniques or kernel exploits.

```
uname -a
```

Figure 5 – uname -a reveals: Linux metasploitable 2.6.24-16-server, kernel from April 2008

Result: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux. The kernel is from 2008 – nearly 18 years old – making it trivially vulnerable to numerous additional local privilege escalation exploits even if the initial access level were limited.

6.2 User Account Enumeration

The /etc/passwd file was read to enumerate all user accounts on the system. This file is readable by all users on a Linux system and reveals every account including service accounts, their home directories, and default shells.

```
cat /etc/passwd
```

Figure 6 – /etc/passwd: full list of system accounts including msfadmin, user, postgres, mysql, tomcat55

Figure 7 – /etc/passwd continued showing all service accounts on the system

Notable accounts identified: root, msfadmin (UID 1000 – primary admin), user (UID 1001), postgres, mysql, tomcat55, ftp, proftpd, and snmp. The presence of these service accounts confirms the wide range of services running on the target.

6.3 Password Hash Extraction

HIGH SEVERITY – Shadow File Accessed and Password Hashes Extracted

The /etc/shadow file contains hashed passwords for all user accounts and is normally restricted to the root user only. Because the exploit granted root-level access, this file was read in full. In a real attack, these hashes would be fed into offline password cracking tools such as Hashcat or John the Ripper.

```
cat /etc/shadow
```

Figure 8 – /etc/shadow exposed: hashed passwords for root, msfadmin, user, postgres, mysql, and all service accounts

Figure 9 – /etc/shadow continued: hashes for all remaining accounts extracted

The shadow file revealed hashed credentials for every account on the system. The root account hash and several service account hashes were successfully extracted. These SHA-512 hashes could be cracked offline given sufficient time and computational resources, potentially yielding plaintext passwords reused across other systems.

6.4 Network Interface Enumeration

The ifconfig command was run to confirm the network configuration from inside the compromised machine. This validates that the attacker is genuinely operating within the target system and reveals its full network presence.

```
ifconfig
```

Figure 10 – ifconfig confirms target IP 192.168.56.102, MAC address 08:00:27:47:a3:22, full network configuration

The output confirmed the target's IP address as 192.168.56.102 with MAC address 08:00:27:47:a3:22 (Oracle VirtualBox NIC), consistent with the original scan results.

6.5 Network Host Discovery (Pivoting)

The arp -a command was executed to identify other hosts visible from inside the compromised machine. In a real engagement this is the first step of network pivoting – using one compromised machine to discover and attack further targets on the internal network.

```
arp -a
```

Figure 11 – arp -a reveals two additional hosts: 192.168.56.100 and 192.168.56.101 (Kali attacker machine)

Two additional hosts were discovered: 192.168.56.100 (likely the VirtualBox DHCP server/gateway) and 192.168.56.101 (the Kali Linux attack machine itself). In a real engagement with a larger network, this step would identify other internal targets for lateral movement.

7. Findings Summary

#	Finding	Severity	Evidence
F-01	vsftpd 2.3.4 Backdoor – CVE-2011-2523	CRITICAL	Figures 2, 3, 4
F-02	Unauthenticated Remote Root Shell Obtained	CRITICAL	Figure 4
F-03	/etc/shadow Accessed – All Password Hashes Extracted	CRITICAL	Figures 8, 9
F-04	OS Kernel from 2008 – Highly Vulnerable to Local Exploits	High	Figure 5
F-05	All User Accounts Enumerated via /etc/passwd	High	Figures 6, 7
F-06	Network Hosts Identified for Potential Lateral Movement	Medium	Figure 11
F-07	Additional Critical Services Identified (port 1524, 6667)	Critical	Nmap scan

8. Impact Assessment

The successful exploitation of CVE-2011-2523 on the target system demonstrates complete system compromise. The following table summarises the business and technical impact of the identified vulnerabilities:

Impact Category	Description
Confidentiality	All files, credentials, and data on the system are fully exposed to the attacker
Integrity	Attacker has unrestricted ability to modify, plant, or delete any file on the system
Availability	Attacker can shut down, crash, or hold the system hostage at will
Lateral Movement	Compromised machine could be used as a pivot point to attack other network hosts
Credential Risk	Extracted password hashes may be cracked and reused on other systems (credential stuffing)

9. Recommendations

Priority	Recommendation	Finding
Immediate	Remove vsftpd 2.3.4 entirely and replace with a patched FTP server or disable FTP altogether	F-01
Immediate	Close port 1524 (backdoor root shell) and port 6667 (UnrealIRCd backdoor)	F-07
Immediate	Force password resets for all accounts – extracted hashes may have been cracked	F-03
High	Update the Linux kernel from 2.6.24 (2008) to a currently supported version	F-04
High	Restrict /etc/shadow permissions and audit root-level access controls	F-03
High	Disable Telnet (port 23) and enforce SSH-only remote access with key authentication	General
High	Firewall all database ports (3306, 5432) to localhost or VPN access only	General
Medium	Implement network segmentation to prevent lateral movement between hosts	F-06
Medium	Conduct regular vulnerability scans and apply patches on a defined schedule	General
Low	Disable all unnecessary services to reduce the attack surface	General

10. Conclusion

This penetration test successfully demonstrated a full attack chain from initial reconnaissance to complete system compromise. Using a single publicly known vulnerability (CVE-2011-2523) in vsftpd 2.3.4, unauthenticated root-level access was obtained in under two minutes using freely available tools built into Kali Linux.

Post-exploitation activities further confirmed the severity of the compromise: all user accounts were enumerated, all password hashes were extracted from the shadow file, and the internal network was mapped for potential further attacks. A real attacker with this level of access could exfiltrate data, install persistent backdoors, pivot to other hosts, or cause complete system destruction.

The findings of this assessment underscore a fundamental principle of cybersecurity: running outdated software with known vulnerabilities in an exposed environment is equivalent to leaving the front door unlocked. Regular patching, service minimisation, and network segmentation are the most effective defences against attacks of this nature.

End of Penetration Test Report

Classification: CONFIDENTIAL – Portfolio / Educational Use Only